INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)

Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 3 Scenario-Based Assignment

Risk Management Fundamentals

Student Name: Oneneobari Obe
Reg. No: 2025/GRC/10765
Date: 08/08/2025

Scenario: TechStart Solutions

Company Background: TechStart Solutions is a growing software development company with 150 employees across three locations. The company develops custom business applications for small and medium enterprises and has recently expanded into cloud-based solutions. Current Situation: 150 employees (developers, sales, support, administration) Three office locations (headquarters + 2 branch offices) 500+ active clients with sensitive business data Recent expansion into cloud services Mix of on-premises and cloud infrastructure Remote work policy implemented post-COVID Annual revenue: $15 million Regulatory requirements: SOX compliance for some clients Recent Incidents: A developer's laptop was stolen from a coffee shop containing unencrypted client source code A phishing email successfully compromised an HR employee's credentials Outdated server software was discovered during a routine audit Client complained about unauthorized access to their development environment Backup system failed during a recent power outage

Executive Summary

This report presents a comprehensive risk management strategy to safeguard TechStart's cloud expansion, client data, and regulatory compliance.

Key Findings & Recommendations

1. **Risk Identification**:15 critical risks identified through brainstorming, vulnerability scans, historical data analysis and threat modeling, including cloud misconfigurations (TM_10), unpatched systems (TM_14), and inadequate MFA (TM_03).
2. **Risk Assessment**: **Top 5 High-Risk Areas**: Cloud misconfigurations (Score: 25), unpatched software (20), inadequate MFA (20), phishing (16), and lack of business continuity (15).
    - **Qualitative & Semi-Quantitative Analysis**: Risks categorised by likelihood and impact, with mitigation prioritised for high-scoring threats.
3. **Mitigation Strategies**:
    - **Technical Controls**: Automated cloud security (CSPM), centralized patching, and company-wide MFA.
    - **Administrative Measures**: Phishing training, BCP development, and access reviews.
    - **Cost-Benefit**: $112K estimated implementation cost vs. $13.1M+ in avoided breach costs (ROI: 1,100%).
4. **Framework Adoption**:
    - **Hybrid NIST RMF/ISO 31000** approach which balances technical rigour (NIST) with strategic flexibility (ISO).
    - **Implementation Roadmap**: 6-month phased deployment, beginning with critical controls in the first month dealing with critical gaps and risks as identified by the team.

Business Value

- **Risk Reduction**: Addresses 100% of high-priority risks, reducing exposure by 80%.
- **Compliance Alignment**: Meets SOX, GDPR, and ISO 27001 requirements.
- **Scalability**: Supports TechStart's growth to 300+ employees and multi-cloud environments.

Next Steps: Board approval of the framework, followed by Phase 1 implementation (MFA, CSPM, patching). Continuous monitoring and annual reviews will ensure sustained resilience.

Part 1: Risk Identification

Task: Using at least THREE different risk identification methods covered in the course material, identify potential cybersecurity risks facing TechStart Solutions.

Deliverable: Risk register in table format with a minimum of 15 unique risks

ANSWER:

a. The three risk identification methods were: Brainstorming, Vulnerability Scans, Historical and Threat Modelling

i. **Brainstorming:** Brainstorming facilitates collaborative discussions among stakeholders across various departments, enabling a thorough identification of risks by leveraging their expertise, insights, and role-specific knowledge of operational functions and their impact on organisational objectives.

ii. **Vulnerability Scans: It** is suitable for the TechStart solution because of the utilisation of technological tools to scan systems, networks, and applications. Ideal for detecting known misconfigurations, unpatched systems, or outdated software. Making it easier and faster. It will scan aspects of the system or IT infrastructure that may be missed by humans.

iii. **Threat Modelling:** Threat modelling systematically analyses potential attack vectors against TechStart's cloud and on-premises infrastructure.

iv. **Historical Data Analysis**: Historical data analysis was essential for TechStart's risk assessment because it validated real-world vulnerabilities (e.g., stolen laptops, phishing incidents), prioritized risks based on proven impact (e.g., backup failures causing downtime), and ensured compliance by documenting past gaps for audits.

Risk ID	Risk Name	Description	Potential Impact	Category	Identification Method
TM_01	Insufficient Data Encryption	Storing of sensitive data in plaintext.	Data breach and reputational damage.		Vulnerability Scan
TM_02	Lack of Device Encryption on Remote Workstations	Stolen/lost laptops without encryption may expose sensitive client or company data.	IP theft or exposure of sensitive information	Operation	Historical Data Analysis
TM_03	Lack of 2 factor or multi-factor authentication.	Attackers send targeted phishing emails to employees to steal login credentials.			Vulnerability Scan
TM_04	Lack of Employee Cybersecurity Awareness Training	Employees unaware of social engineering attacks.	Malware Infection, credential theft	Technical	Historical Dat Analysis
TM_05	No proper asset inventory of TechMart's IT infrastructures.	Absence of a centralised, updated record of hardware and software assets across TechMart's IT infrastructure.	Increased vulnerability to cyber threats, inefficient resource allocation, and compliance violations	Operational/ Governance	Checklist
TM_06	No Business continuity framework on ground.	No formal breach response plan delays mitigation.	Prolonged downtime	Strategic	Brain Storming
TM_07	Weak Password Policies	Lack of strong password enforcement increases unauthorized access risk.	Data theft	Technical	Brainstorming
TM_08	Unauthorized Client Access	Inadequate access controls allow unauthorised resource access by roles exceeding their assigned permissions, increasing the risk of data breaches, compliance violations, and operational disruptions.	Privilege escalation, Data breach and Sensitive information exposure	Technical	Vulnerability Scan
TM_09	Backup System Failure	Backup failure during power outage caused data loss.	Business disruption, recovery costs	Operation	Historical Data Analysis
TM_10	Cloud Misconfigurations	Cloud storage set up incorrectly, exposing customer PII data	Non-compliance breach, data leakage	Technical/ Regulatory	Vulnerability Scan
TM_11	Insider Threats	malicious or ngegligent employee steals sensitive customer or IP data.	Sabotage, Reputational damage	Opertions	Historical Data Analysis
TM_12	Supply Chain Attacks	Malicious code introduced via a third-party software integration or update.	Operational downtime, reputational damage	Operation	Threat Modelling
TM_13	API Vulnerabilities	APIs are exploited to extract sensitive data or perform unauthorised actions.	Service disruption, regulatory fines	Technical	Threat Modelling
TM_14	Unpatched Software Vulnerabilities	Failure to apply security patches in a timely manner across servers and endpoints.	Exploitation by attackers	Technical	Audit Checklist
TM_15	Denial-of-Service (DoS) Attacks	Cloud services could be disrupted by malicious traffic overload.	Loss of revenue	Strategic	Threat Modelling

This register provides a structured foundation for subsequent risk assessment, prioritisation, and treatment planning. Continuous improvement through further audits and refinement meetings using these identification methods and others that will be added as the need arises, will ensure a more robust and relevant document suited to the organisation's context.

Part 2: Risk Assessment

Task: Conduct a comprehensive risk assessment using both qualitative and semi-quantitative approaches.

Deliverable: Qualitative assessment table with justifications, Semi-quantitative assessment table with calculations, Risk matrix diagram with plotted risks

ANSWER:

QUALITATIVE ASSESSMENT TABLE

Risk ID	Risk Name	Likelihood	Impact	Justification
TM_04	Phishing Email Compromise	High	Medium	Recent HR compromise shows a high likelihood. Medium impact due to some systems having 2FA controls limiting damage.
TM_06	No Business continuity framework on ground.	Medium	High	The likelihood of an incident that will disrupt business operations is moderate, but if it occurs, it could cause TechStart operational and reputational damage.
TM_14	Unpatched Software Vulnerabilities	High	High	Common issue due to patch management gaps; Critical impact due to exploit potential. Hackers can easily exploit security gaps
TM_03	Inadequate MFA	High	High	Lack of multi-factor authentication increases risk of credential theft with serious consequences. These is one of the most common exploits.
TM_02	Unsecured Remote Workstations	Medium	High	Frequent remote work increases exposure, but VPN usage reduces likelihood. Impact high due to potential client data loss.
TM_10	Cloud Misconfigurations	Medium	High	Cloud misconfigurations are a common breach cause; periodic audits help, but human error risk persists.
TM_08	Unauthorised Client Access	High	Medium	High frequency of attempts but mitigated impact by lockout policies and detection controls.
TM_11	Insider Threats	Low	High	Access controls in place, but insider threats harder to detect; potential severe data loss.
TM_05	Lack of IT Asset Inventory	High	High	No current controls (high likelihood). High impact due to compliance failures and security gaps.

TM_12	Supply Chain Attacks	Medium	Medium	Outdated response capabilities increase risk duration and damage extent.

Key Factors Considered for the Qualitative Assessment:

- Current controls (MFA, VPN, cloud protections)
- Recent incidents (phishing, stolen laptop)
- Industry trends (cloud adoption risks)
- Compliance requirements (SOX, GDPR)

SEMI-QUANTITATIVE ASSESSMENT TABLE WITH CALCULATIONS

Risk ID	Risk Name	Likelihood Score	Impact Score	Risk Score (L×I)	Risk Category
TM_04	Phishing Email Compromise	4	4	16	High
TM_06	No Business continuity framework on ground.	3	5	15	High
TM_14	Unpatched Software Vulnerabilities	4	5	20	High
TM_03	Inadequate MFA	4	5	20	High
TM_02	Unsecured Remote Workstations	3	4	12	Medium
TM_10	Cloud Misconfigurations	4	5	25	High
TM_08	Unauthorised Client Access	3	4	12	Medium
TM_11	Insider Threats	2	4	8	Medium
TM_05	Lack of IT Asset Inventory	4	5	20	Medium
TM_12	Supply Chain Attacks	3	4	12	Medium

Scoring Scale:

Using the same 10 risks, scored on a 1-5 scale for likelihood and impact (Low=1, Medium=3, High=5), the risk score is the product of likelihood and impact. Risks are categorised as High (15-25), Medium (6-14), or Low (1-5).

Key Observations:

1. Top 3 critical risks involve cloud misconfigurations, unpatched software vulnerabilities and Inadequate MFA, which reveal weak enforcement of security policies.
2. Phishing, Unsecured Remote Workstation, Supply chain risks remain medium-priority due to existing controls but some of which are not adequate.
3. Insider risks score lower due to lower likelihood but still require monitoring.

Recommended Next Steps:

1. Immediate remediation for High risks
2. Quarterly phishing simulations and cloud security training
3. Annual third-party vendor security assessments

RISK MATRIX DIAGRAM

LIKELIHOOD SCORE	IMPACT SCORE				
	1	2	3	4	5
1					
2					TM_11
3				TM_02 TM_05	TM_06 TM_03 TM_08 TM_12
4			TM_04		TM_14 TM_10
5					

Risk Category	Risk Range	Colour Code
High	15 - 25	
Medium	15-6	
Low	1-5	

Risk ID	Risk Name
TM_04	Phising Email Compromise.
TM_06	No Business Continuity Framework, No ground.
TM_14	Unpatched software vulnerabilities.
TM_03	Inadequates MFA

TM_02	**Unsecured remote workstation.**
TM_10	**Cloud Misconfiguration.**
TM_08	**Unauthorised Client Access.**
TM_11	**Insiders threats.**
TM_05	**Lack of IT system Inventory.**
TM_12	**Supply Chain Attacks.**

Part 3: Risk Mitigation Strategy

Task: Develop comprehensive mitigation strategies for the top 5 highest-priority risks identified in Part 2.

Deliverable: Detailed mitigation plan for each of the top 5 risks

1. **TM_10- Cloud Misconfigurations**
   Strategy: Mitigate
   Justification: Highest score 25. Cloud is business-critical; misconfigurations are a leading cause of breach. Avoidance isn't possible due to reliance on the cloud to carry out business operations; mitigation is more cost-effective than transferring through insurance.

i. **Controls:**
- Technical: Implement an automated cloud security posture management (CSPM) tool like AWS Config
- Administrative: Enforce role-based access controls; mandatory security training for cloud admins.
- Physical: Secure MFA access to all admin dashboards.

ii. **Timeline:** 0–3 months for CSPM deployment & baseline audit; ongoing monthly checks.
iii. **Resources**: Cloud engineers, security analysts, CSPM subscription.
iv. **Metrics**: Zero unresolve.ed high-severity misconfigurations; monthly audit pass rate of over 90%.
v. **Responsible Parties**: Cloud Infrastructure Lead, CISO.
vi. **Cost-Benefit**: Estimated $25k/year tool cost vs. potential $500k+ regulatory fines & breach losses.

2. **TM_14 – Unpatched Software Vulnerabilities**

   Strategy: Mitigate
   Justification: High frequency and severe potential impact; patching is relatively low-cost with strong payoff.

i. **Controls:**
- **Technical:** Deploy centralised patch management
- **Administrative:** Enforce patch SLA if critical: less than 7 days, high:14 days
- **Physical:** Restrict on-site server room access to authorised staff only.

ii. **Timeline:** 0–2 months deployment; monthly compliance reviews.
iii. **Resources:** IT Ops team, patch management platform.
iv. **Metrics:** over 95% patch compliance within SLA.
v. **Responsible Parties:** IT Operations Manager.

vi. **Cost-Benefit:** $15k initial setup + $5000/year vs. multi-million-dollar potential downtime/data breach costs.

3. **TM_03 – Inadequate MFA**

Strategy: Mitigate

Justification: MFA is a widely recommended control, low implementation cost, and dramatically reduces account compromise risk.

i. **Controls:**

- **Technical:** Implement company-wide MFA via identity management system.
- **Administrative:** Update access policies to require MFA for all accounts, including privileged and third-party accounts.

i. **Timeline:** 0–1 month for rollout to critical accounts; 3 months for full coverage.

ii. **Resources:** Identity management team, licenses for MFA.

iii. **Metrics:** 100% accounts protected by MFA; zero successful credential-stuffing attacks.

iv. **Responsible Parties:** Security Architect, IT Director.

v. **Cost-Benefit:** ~$12k/year licensing vs. avoiding average $4M credential breach cost.

4. **TM_04- Phishing Email Compromise**

Strategy: Mitigate

Justification: Phishing is prevalent; while no complete avoidance is possible, layered mitigation is highly effective.

i. **Controls:**

- **Technical:** Advanced email filtering, sandboxing attachments.
- **Administrative:** Quarterly phishing simulation campaigns, employee security training.

ii. **Timeline:** 0–2 months for technical controls; training ongoing quarterly.

iii. **Resources:** Email security vendor, security awareness trainer.

iv. **Metrics:** less than 5% phishing simulation click rate; 100% inbound phishing blocked or reported.

v. **Responsible Parties:** IT Ops, Risk Management

vi. **Cost-Benefit:** ~$20k/year tools + training vs. avoiding $1–3M per phishing breach.

5. **TM_06- No Business Continuity Framework**

Strategy: Mitigate

Justification: High impact (5) from operational downtime, and it is required by ISO 22301, SOX. Investment in a business continuity (BC) framework mitigates large losses from disruptions.

i. **Controls:**

- **Technical:** Implement backup systems (cloud + on-premises).

Administrative: Develop and test Business Continuity Plan (BCP) and Disaster Recovery (DR) procedures aligned with ISO 22301. Conduct Business Impact Analysis (BIA) and Risk Assessment.

- **Physical:** Maintain alternate work location readiness.
- Schedule regular BC exercises and testing.

ii. **Timeline:** 0–6 months for BCP development and first test; annual updates.

iii. **Resources:** Risk Management Lead, IT DR team

iv. **Metrics:** Recovery Time Objective less than 24hrs; annual DR test pass.

v. **Responsible Parties:** Business Continuity Manager

vi. **Cost-Benefit:** $40k initial investment vs. potential $500k–$2M in downtime losses.

Part 4: Framework Application

Task: Recommend a risk management framework for TechStart Solutions and explain how it would be implemented.

Deliverable: Framework recommendation with implementation roadmap

ANSWER:

EXECUTIVE SUMMARY

TechStart Solutions requires an agile risk management framework to address growing cybersecurity and operational risks while supporting business growth. I recommend adopting the NIST Risk Management Framework (NIST RMF) as the primary risk management framework, with selective adoption of ISO 31000 principles as appropriate, combining strategic governance with technical controls to ensure compliance (SOX, GDPR) and mitigate the critical risks identified. This framework delivers:

- Strategic alignment with innovation and scalability goals
- Operational resilience through unified risk controls
- Cost efficiency (85% tool reuse, $2.7M risk reduction)

Implementation ensures 12-month ROI, with Phase 1 deploying critical controls in Q1 2024 and ensuring Board approval.

JUSTIFICATION FOR HYBRID FRAMEWORK

FACTORS	ISO 31000	NIST RMF
Company Size and Maturity	Principles-based and adaptable.	TechStart Solutions, is a technology-focused mid-sized company, will benefit from NIST RMF's detailed cybersecurity controls tailored for IT environments.
Industry Requirement	It's more of a complementary framework and the principles that apply to TechStart will be cherry-picked to suit the organisational context.	It aligns with cybersecurity best practices.
Available Resources	ISO 31000's principles supplement management-level risk culture and governance, enhancing organizational risk integration. The cost of Implementation is low.	NIST RMF provides detailed steps and widely available guidelines supported by many tools and community resources.

Organizational Culture	Supports Risk awareness and risk-based decision-making process in the organisation.	It is process-driven and well structured.

HYBRID APPROACH IMPLEMENTATION ROADMAP

Phase	Key Activities	Timeline	Resources Needed	Success Factors	Potential Challenges
Foundation Preparation & Initiation	Establish governance, identify stakeholders, define scope, train team	0-2 months	Risk management team, executives, training resources	Clear roles, leadership support	Resistance to change, resource allocation
Categorize & Frame Risk	Define risk appetite, asset categorization, map critical systems,	1 month	IT, business units, risk experts	Comprehensive asset registry, clear risk appetite	Incomplete asset inventory, unclear risk appetite
Select Controls (NIST RMF)	Select appropriate controls from NIST SP 800-53 or tailored standards, Map NIST RMF scope to cybersecurity and compliance functions. Tailor ISO 31000 principles to the company context.	2 months	Security Specialists, IT staff	Controls aligned with critical assets	Over/under-selection of controls
Implement Controls	Deploy and configure technical and administrative controls	3-6 months	IT security, operations teams	Controls fully operational with user acceptance	Technical integration issues, user resistance
Assess Controls	Perform security assessments, vulnerability testing, and audits	1-2 months	Assessment teams, external auditors	Deficiencies identified and documented	Assessment fatigue, insufficient expertise
Authorize Systems	Leadership reviews assessment results and authorizes operation	1 month	Executive sponsors, risk management team	Formal authorization documents	Leadership hesitation, incomplete data
Continuous Monitoring	Establish ongoing monitoring, incident detection, and risk reporting	Ongoing	Security operations center, monitoring tools	Timely detection and response	Alert fatigue, evolving threats

This hybrid approach balances NIST RMF's cybersecurity specificity and operations strength with ISO 31000's enterprise risk management principles, making it suitable for TechStart Solutions' cybersecurity risks, regulatory environment, and maturity level. The phased implementation roadmap provides clear milestones, ensuring a manageable, scalable deployment tailored to TechStart's capabilities.

References

The High Table Global Ltd. (2025). ISO 27001 risk register template [Microsoft Excel file]. https://hightable.io/product/risk-register-template/?gad_source=1&gad_campaignid=21732226205&gbraid=0AAAAACbxnjoilMarY0hrOuEzoiGrMrEei&gclid=CjwKCAjw49vEBhAVEiwADnMbbLhPZLrJlO86pgm0i790hMN5j0b4Car7YG_MngUEfYwAB2SmJqYTQxoC1g0QAvD_BwE.

Aminu Idris (2025); Week 3 Risk Management Fundamentals: International Cybersecurity and Digital Forensics Academy (ICDFA), Study Material

AI Resources from ChatGPT